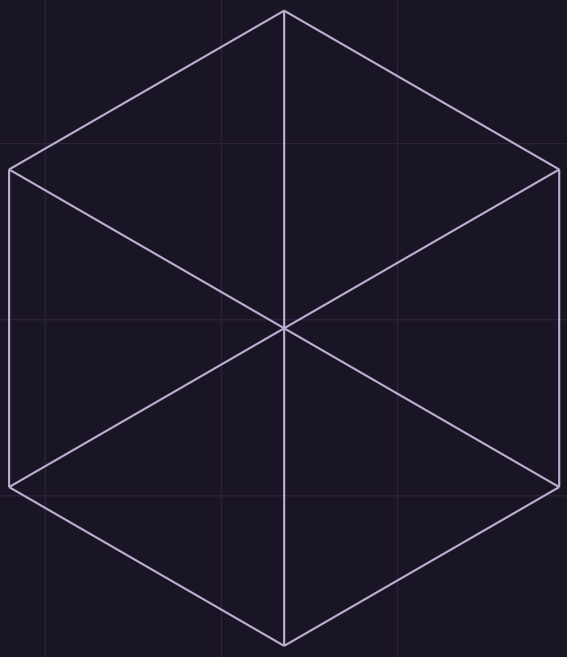
NEODA · WHITEPAPER

Marco de Exposición Tecnológica 2027

Datos, IA y ciberriesgo: un modelo para cuantificar la exposición y priorizar inversiones ante NIS2, DORA y el Reglamento de IA.



Versión 1.0 · Noviembre 2026 · Documento de carácter informativo

01 · Resumen ejecutivo

Una exposición que no se mide no se gestiona

Las organizaciones gastan cada año en datos, inteligencia artificial y ciberseguridad, pero rara vez saben cuánto riesgo asumen ni cuánto valor no están capturando. Este documento propone un modelo sencillo para expresar ambas cosas en términos financieros, de modo que el comité de dirección pueda comparar y priorizar inversiones con los mismos criterios que aplica a cualquier otra decisión.

El marco tiene tres componentes: un modelo de exposición que estima pérdidas anuales esperadas, una matriz de priorización que ordena las acciones por impacto y esfuerzo, y un checklist de cumplimiento alineado con NIS2, DORA y el Reglamento Europeo de Inteligencia Artificial.

Las cifras de ejemplo de este documento son ilustrativas y no corresponden a ningún cliente real. Se incluyen únicamente para mostrar cómo se aplica el método.

02 · El punto ciego

Lo que no aparece en el cuadro de mando también cuesta dinero

Tres patrones explican la mayoría de incidentes graves y de inversiones tecnológicas que no dan retorno:

Patrón	Qué ocurre	Coste que no aparece
Exposición no medida	Accesos heredados, proveedores conectados a sistemas críticos y configuraciones cloud sin revisar.	Pérdidas esperadas por incidentes, sanciones y paradas.
Datos sin uso	Información almacenada, duplicada y sin modelo de gobierno.	Coste de plataforma y almacenamiento sin retorno en decisiones.
IA sin perímetro	Pilotos aislados, herramientas no autorizadas e información sensible fuera de control.	Riesgo regulatorio, fuga de información y retorno no defendible.

03 · Modelo de exposición

Pérdida esperada anual por dominio

Para cada riesgo identificado se estiman dos variables: la probabilidad anual de que se materialice y el impacto económico si ocurre (coste directo, sanciones, paradas y reputación). La exposición anual del dominio es la suma de esas pérdidas esperadas:

$$E = \Sigma\ (P_i \times I_i) + C_{datos} + C_{IA}$$

donde P_i es la probabilidad anual del riesgo i, I_i su impacto en euros, C_{datos} el coste de datos sin uso y C_{IA} el coste de pilotos de IA sin resultado medible. Los dos últimos términos se calculan a partir del gasto anual en plataformas y proyectos sin indicadores de retorno.

Ejemplo ilustrativo. Un riesgo de acceso no revisado a un sistema crítico con probabilidad anual del 4 % y un impacto de 2,5 M€ aporta una pérdida esperada de 100.000 € al año. Reducirlo a una probabilidad del 1 % con una inversión de 30.000 € anuales deja un ahorro esperado de 75.000 € frente a la inversión.

04 · Tres dominios, tres indicadores

Qué medir en cada área

Dominio	Indicador de exposición	Indicador de retorno
Arquitectura de datos	Activos sin propietario o sin clasificación; linaje incompleto.	Tiempo desde la pregunta de negocio hasta la respuesta fiable.
Inteligencia artificial	Modelos en producción sin evaluación de riesgos ni supervisión humana.	Margen o coste afectado por cada caso de uso desplegado.
Ciberseguridad	Superficie de ataque expuesta, incluida la cadena de suministro.	Tiempo medio de detección y de contención.

Los indicadores de exposición responden a «qué podría costarnos». Los de retorno responden a «qué estamos obteniendo». Un comité necesita ambos para decidir.

05 · Matriz de priorización

Impacto frente a esfuerzo

Cada acción identificada se sitúa según el impacto económico esperado y el esfuerzo de ejecución. Las cuatro zonas resultantes indican qué hacer primero:

Zona	Criterio	Decisión
Hacer ya	Alto impacto, esfuerzo bajo o medio	Asignar propietario y plazo en el próximo ciclo.
Planificar	Alto impacto, esfuerzo alto	Hoja de ruta por fases con coste y retorno por iniciativa.
Automatizar	Impacto medio, esfuerzo bajo	Delegar en el equipo operativo con métricas mensuales.
Revisar	Impacto bajo	Mantener bajo observación; revisar en la siguiente auditoría.

06 · Marco normativo

NIS2, DORA y el Reglamento de IA

NIS2 (Directiva (UE) 2022/2555) exige medidas de gestión de riesgos de ciberseguridad y notificación de incidentes a las entidades esenciales e importantes. Su aplicación concreta depende de la transposición nacional en cada Estado miembro.

DORA (Reglamento (UE) 2022/2554) establece requisitos de resiliencia operativa digital para entidades financieras y sus proveedores de servicios TIC. Es aplicable desde el 17 de enero de 2025.

El Reglamento de IA (Reglamento (UE) 2024/1689) establece obligaciones según el nivel de riesgo de cada sistema, con un calendario de aplicación escalonado. La fecha que afecta a cada sistema debe verificarse caso por caso.

Este resumen es informativo y no constituye asesoramiento jurídico. Para cada caso concreto, conviene contrastarlo con su asesor legal.

07 · Checklist de cumplimiento

Preguntas que el comité debería poder responder

	Pregunta	Marco
☐	¿Existe un inventario actualizado de activos digitales y de sus propietarios?	NIS2 · DORA
☐	¿Están documentados los proveedores TIC y sus accesos a sistemas críticos?	DORA
☐	¿Se notifican los incidentes significativos dentro de los plazos establecidos?	NIS2 · DORA
☐	¿Se prueban periódicamente los planes de continuidad y de respuesta?	DORA
☐	¿Hay un registro de los sistemas de IA en uso y de su nivel de riesgo?	Reglamento IA
☐	¿Existe supervisión humana y trazabilidad en los casos de uso de IA?	Reglamento IA
☐	¿Está clasificado el dato por sensibilidad y linaje auditable?	Buenas prácticas
☐	¿Se calcula la exposición anual en euros y se revisa cada trimestre?	Este marco

08 · Próximos pasos

Cómo empezar

Un primer ciclo de trabajo suele durar entre dos y tres semanas: inventario y hallazgos, cálculo de la exposición inicial, matriz de priorización y una hoja de ruta con coste y plazo por iniciativa. El resultado es un documento que el comité puede aprobar, y un conjunto de indicadores que se revisan cada trimestre.

Para una primera conversación de 45 minutos, escriba a contacto@neoda.com. Se firma un acuerdo de confidencialidad (NDA) desde la primera reunión.